

Social Engineering

OLIVIER BLAZY

EMMANUEL CONCHON (EMMANUEL.CONCHON@UNILIM.FR)

1

Tout l'art de la guerre est basé sur la duperie.

L'art de la Guerre, (-400), [Sun-Tzu](#)

2

We are inclined to believe those whom we do not know because they have never deceived us.

Samuel Johnson

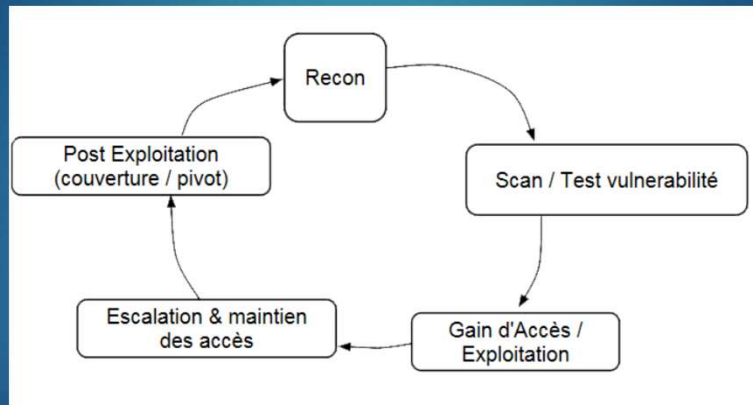
3

Définition

- ▶ L'Ingénierie sociale regroupe tous les moyens où quelqu'un essaie de manipuler une personne pour accomplir une action qui peut être ou ne pas être dans l'intérêt de la cible
 - ▶ Révéler des informations confidentielles
 - ▶ Créer/suspendre un accès
 - ▶ Souvent couplé à des techniques d'OSINT (OpenSource INtelligence)
 - ▶ Peekyou, lullar, IWB, EDGAR, YouGetSignal...

4

Méthodologie



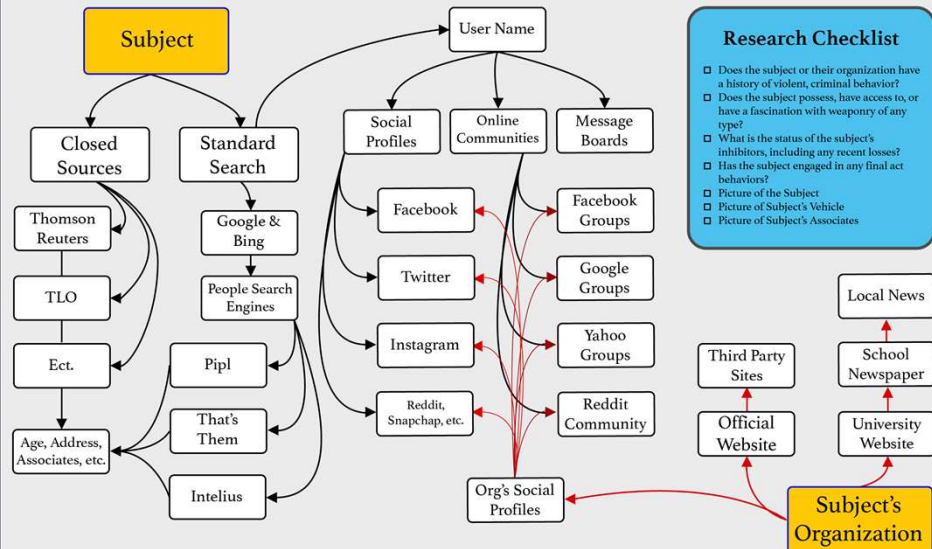
5

La reconnaissance

- ▶ OSINT (Open Source Intelligence)
 - ▶ Internet
 - ▶ Site web de l'entreprise, Réseaux sociaux, Données publiques, Informations sur les DNS
 - ▶ Archives: IWB : <http://archive.org/web/web.php>
 - ▶ Lettres d'informations, journaux, partenaires : Fusions, outsourcing, . . .
- ▶ SIGINT (Signals Intelligence)
 - ▶ Scan de réseaux wifi, SMS, Tracking GPS...
- ▶ HUMINT (Human Intelligence)
 - ▶ Social Engineering: Moyen le plus simple pour accéder à l'information

6

OSINT Mind Map



7

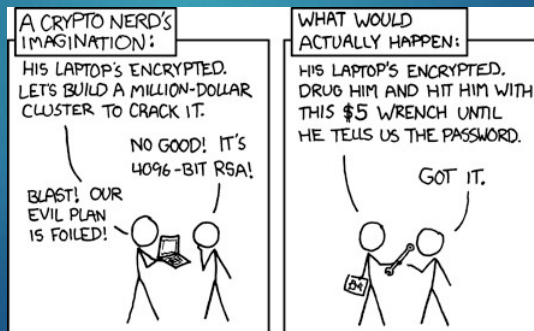
Social Engineering

- ▶ Plus une entreprise a de salariés, plus il y a de maillons faibles potentiels
 - ▶ Difficile de s'en protéger
 - ▶ Eduquer les gens
 - ▶ S'entraîner à déceler et résister aux techniques
 - ▶ publicités, laugh tracks, ...
 - ▶ S'entraîner ...
- ▶ Les attaquants utilisent des méthodes qui ne relèvent pas uniquement de la technique
 - ▶ Manipuler des gens, au lieu de machines / protocoles pour divulguer des informations confidentielles ou gagner un accès
 - ▶ Profite des réponses prévisibles des triggers psychologiques humains

8

Collecte d'informations

- ▶ Directes (Interactions avec la cible)
 - ▶ Téléphone, en personne, en ligne
 - ▶ Arnaques au président...
- ▶ Observations indirectes
- ▶ Inférences



9

Plan

- ▶ Evaluation de la situation
- ▶ Pourquoi ça marche, ou le cerveau notre meilleur ennemi
- ▶ Cycle d'attaque
- ▶ Vecteurs d'attaques
- ▶ Contremesures

10

Les bonnes questions à se poser

- ▶ Où est-ce que mon infrastructure est la plus vulnérable ?
- ▶ Quelles sont les zones critiques où je dois utiliser les ressources disponibles pour gérer le risque
- ▶ Quel est le plus grand risque pour la sécurité de mon entreprise ?
 - ▶ En 2004, Gartner a annoncé que le plus grand risque de sécurité pour les grosses entreprises et les utilisateur d'Internet serait dans les 10 prochaines années des attaques de SE de plus en plus sophistiquées pour contourner les défenses IT.
 - ▶ En 2019, le FBI a indiqué que c'était la plus grande source de pertes de revenus pour les entreprises devant les Zero-day

11

Contexte

- ▶ Qui mène des attaques par SE
 - ▶ Les pirates, cyber-criminels, escrocs (scam artist)
 - ▶ Les espions missionnés par des entreprises concurrentes
 - ▶ Des agents de puissances étrangères
 - ▶ Des terroristes
 - ▶ Des employés mécontents
- ▶ Que cherchent-ils
 - ▶ Vos informations voire vos données compromettantes
 - ▶ Vos secrets commerciaux
 - ▶ Votre argent
 - ▶ Vos ressources IT

12

Contexte

- ▶ Toujours garder à l'esprit qu'il est plus facile de contourner un humain que de multiples défenses techniques car cela marche
 - ▶ les gens sont fait pour répondre à certains déclencheurs
- ▶ Prise de décision systémique
 - ▶ Un bon employé doit être autonome et prêt à prendre des décisions.
 - ▶ Approcher les problèmes de façon rationnelle
 - ▶ Ignorer les information non importantes
 - ▶ Estimer l'importance d'une information
 - ▶ Garder l'esprit ouvert
 - ▶ Résister la tendance naturelle pour les biais

13

We don't evaluate security trade-offs mathematically. . . instead, we have shortcuts, rules of thumb, stereotypes, and biases ? Generally known as heuristics.

The problem is that [heuristics] can fail us. . . Our social and technological evolution has vastly outpaced our evolution as a species, and our brains are stuck with heuristics that are better suited to living in primitive and small family groups.

The Psychology of Security, 2007, [Bruce Schneier](#)

14

Exploiter les bases évolutives

- ▶ Expérience du photocopieur, Harvard 1973
 - ▶ Puis-je vous passer devant pour faire une copie ? 62 %
 - ▶ Puis-je vous passer devant pour faire une copie car je suis pressé ? 94 %
 - ▶ Puis-je vous passer devant pour faire une copie car je dois faire une copie ?
- ▶ L'existence d'une raison suffit. (Base primitive ?)

15

Exploiter les bases évolutives

- ▶ Les biais du cerveau humain
 - ▶ Réciprocité
 - ▶ Consistance
 - ▶ Preuve Sociale
 - ▶ Appréciation
 - ▶ Autorité
 - ▶ Pénurie
- ▶ En pratique ce ne sont que des biais pour augmenter la probabilité de succès.
 - ▶ Il faut parfois un peu de finesse.

16

La réciprocité

- ▶ Nous retournons une faveur, peu importe celle initiale
 - ▶ Même si nous ne désirions pas celle initiale
- ▶ Souvent utilisé par les charités en donnant une fleur, une boisson, un encas, une blague avant de demander des dons
- ▶ Exploite la tentation de donner en retour.
 - ▶ Nigerian Scam
- ▶ Fonctionne aussi lors de négociations. . .
- ▶ Application en SE: Permet de lancer des demandes compliquées
 - ▶ "Pour enlever les virus de votre ordinateur, j'aurais besoin de vos identifiants de compte "

17

La consistance

- ▶ Nous essayons de rester cohérent avec nos actions passées même si les raisons ont changées depuis
 - ▶ Répondre à un sondage sans engagement
 - ▶ Avoir une demande de don/d'achat 2 semaines plus tard
 - ▶ Club de gym
- ▶ Exploité par les vendeurs
 - ▶ Vous commencez à remplir un formulaire sans vous engager ce qui généralement vous fait donner beaucoup d'informations personnelles
 - ▶ (nom, adresse, date de naissance, SSN, . . .)
 - ▶ Le cerveau se commit et décide de rester consistant et ce, même si le message change



18

La preuve sociale

- ▶ Nous essayons de faire et de penser ce que les autres personnes qui nous ressemblent font et pensent
 - ▶ Fonctionne quand même si les gens en sont conscients
 - ▶ Exemples:
 - ▶ Laugh tracks
 - ▶ Mouvements de foules
 - ▶ En cas de malaise dans un groupe, les gens se figent et attendent que quelqu'un bouge
- ▶ Application en SE:
 - ▶ Name Dropping
 - ▶ Bob m'a donné son mot de passe, et vous?

19

Appréciation / Similarité

- ▶ On coopère plus facilement avec les gens qui semblent nous apprécier
 - ▶ Good cop, bad cop
- ▶ Vendeur : "Votre ami m'a suggéré de vous contacter" (Recommendation engine)
- ▶ La flatterie marche, même si elle est mauvaise.
 - ▶ Vous avez un très joli tabouret
 - ▶ Le fait d'essayer de flatter est pris pour de la flatterie
- ▶ Même genre de réaction si on se trouve des points communs (imaginaires ?)

20

L'autorité

- ▶ On coopère avec une personne qui semble être en charge
 - ▶ Parfois sans se poser de questions, trop littéralement (Yale '74, Milgram)
 - ▶ Effet blouse blanche, uniforme, badges, sécurité, . . .
- ▶ Fonctionne de manière très efficace dans les structures de type militaire par exemple

21

La pénurie

- ▶ On surévalue, l'apparente rareté d'informations :
 - ▶ Célébrations (Noël, Saint-Valentin, Soldes)
 - ▶ Expérience du pot de cookies
 - ▶ Censure (Backfire souvent, et donc peut être exploitée à l'envers)
 - ▶ Act Now! Supplies Are Limited ! Operators Are Standing By !
- ▶ Exemples
 - ▶ Pour gagner un accès
 - ▶ « Je suis ici jusqu'à midi, donc si vous ne m'autorisez pas à accéder à la salle pour résoudre votre soucis, vous devrez attendre un mois de plus, bonne chance pour expliquez cela à votre boss. »
 - ▶ Pour une augmentation
 - ▶ « Vous savez, la boîte XXX m'a contacté récemment pour un job. . . »

22

Le cycle d'attaque

- ▶ Récupération d'informations
- ▶ Établissement de la confiance
- ▶ Exploiter la confiance
- ▶ Utiliser l'information

23

How do you eat an Elephant ?
One bite a time

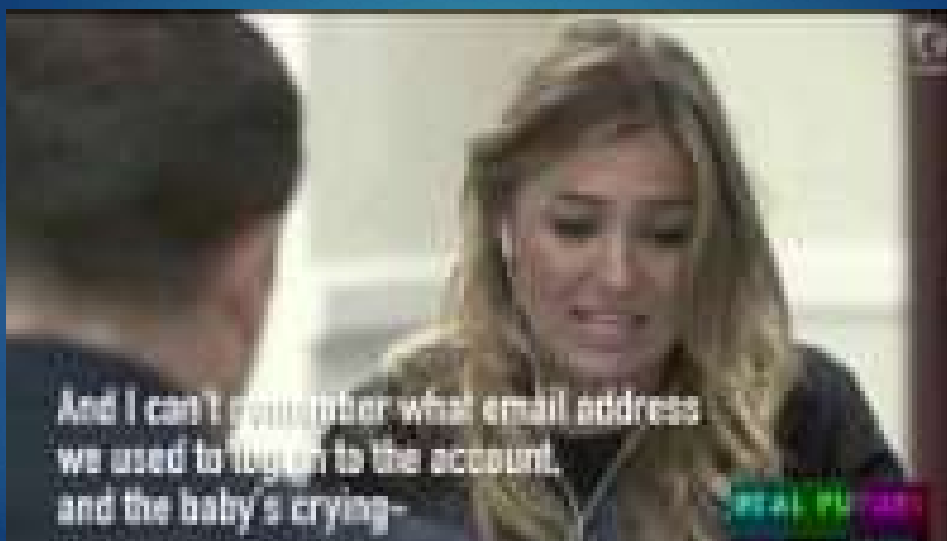
24

Les principaux vecteurs d'attaques

- ▶ Le téléphone (Vishing)
 - ▶ Faible risque, forte récompense
 - ▶ Peut être utilisé de n'importe où sur le globe
 - ▶ Simple de masquer sa vraie identité
 - ▶ Difficile à prévenir
 - ▶ Permet de toucher les bonnes personnes rapidement si on connaît la structuration de l'entreprise cible
- ▶ Pour l'exploiter:
 - ▶ Trouver le maillon faible
 - ▶ Récupérer des informations apparemment innocentes
 - ▶ Etablir ou réactiver une relation

25

Les principaux vecteurs d'attaques



26

Les principaux vecteurs d'attaques

- ▶ En personne
 - ▶ Rentre en personne dans les locaux et interagit avec le personnel
 - ▶ Demande, soudoie, ou effraye pour obtenir de l'information
 - ▶ Permet d'obtenir beaucoup d'information mais avec un vrai risque
 - ▶ Peut se faire arrêter / identifier
 - ▶ Dernier recours
- ▶ Techniques:
 - ▶ Surveillance
 - ▶ Piggybacking ou tailgating (suivre une personne autorisée)
 - ▶ Shoulder surfing (regarder par-dessus l'épaule)
 - ▶ Eavesdropping
- ▶ Lieux
 - ▶ Réception
 - ▶ Salle de courriers
 - ▶ Coin fumeur
 - ▶ Machine à café
 - ▶ Open office

27

Les principaux vecteurs d'attaques

- ▶ Surveillance
 - ▶ Donne des informations clés (organisation du bâtiment, données internes)
 - ▶ Permet de placer du matériel de surveillance
- ▶ Phishing
 - ▶ Peu de risque (pays étranger)
 - ▶ Distribué (Phishing, Spear Phishing)
- ▶ Périphériques USB piégés
 - ▶ Involontairement oubliés dans un endroit où ils seront trouvés
 - ▶ Peuvent apparaître dans des événements légitimes
 - ▶ Une fois connectés, ils vont récupérer des informations (login, données, . . .)

28

Les principaux vecteurs d'attaques

- ▶ Poubelle - Dumpster Diving
 - ▶ Souvent des informations sont jetées sans être broyées (et même si...)
 - ▶ Peu de risques, qui surveille ses poubelles ?
 - ▶ Intermédiaire entre le téléphone et les attaques en personne
 - ▶ Peu de précaution de confidentialité
 - ▶ On peut y trouver régulièrement
 - ▶ Listings téléphoniques
 - ▶ Organigramme
 - ▶ Numéros de compte
 - ▶ Identifiants
- ▶ Reverse Social Engineering
 - ▶ La cible contacte l'attaquant
 - ▶ Fichiers supprimés
 - ▶ Pop-ups
 - ▶ Sentiment d'Urgence

29

Récapitulatif

- ▶ Tout le monde peut être la cible
- ▶ Les attaquants vont choisir le risque minimum
- ▶ Exploite les faiblesses humaines
- ▶ Ces informations vont permettre de s'approcher du but

- ▶ La solution n'est pas technologique

30

You can have the best firewalls, encryption tools and such in place, but they will neither detect nor protect you from a social engineering attack.

Kevin Mitnick

31

Les erreurs fréquentes

- ▶ Les attaques de SE qui fonctionnent demandent de grandes compétences
- ▶ Comme pour les piratages subtils, une attaque de SE demandent du matériel de pointe (micro cameras, dispositifs d'écoute)
- ▶ Nos protocoles de sécurité sont suffisants
- ▶ Seuls des gens crédules peuvent se faire avoir

- ▶ Il ne faut pas traiter le SE comme un problème indépendant

32

La réalité

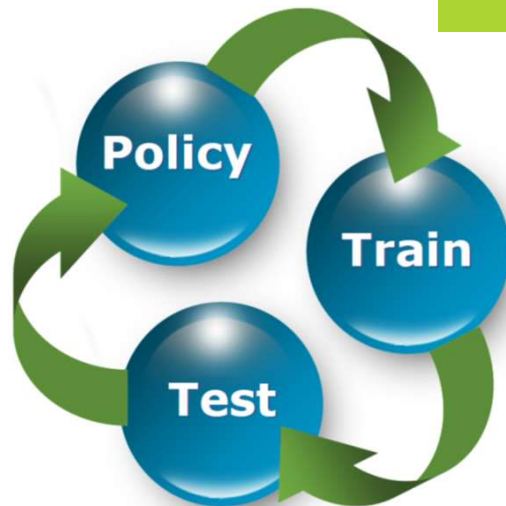
- ▶ La plus grande vulnérabilité d'une entreprise sont les gens
- ▶ Et pas seulement les extérieurs, mais aussi les employés, peu importe leur position hiérarchique
 - ▶ Ils peuvent eux-mêmes être des SE
 - ▶ Professionnels
 - ▶ Amateurs pour avoir une meilleure qualité de vie / travail



33

Quelles contremesures

- ▶ Praticiens de la sécurité
 - ▶ Mettre en place des standards, et des guidelines pour contrer le SE dans les organisations
- ▶ Mouvement d'ensemble
- ▶ Les employés suivront s'ils comprennent pourquoi ils font ça



34

Quelles contremesures

- ▶ Politique
 - ▶ Confronter les extérieurs
 - ▶ Rappel systématique
 - ▶ Pas de piggybacking/tailgating
 - ▶ Procédures pour le Help Desk
- ▶ Identifier les zones vulnérables
 - ▶ Les mots de passe doivent rester personnels
 - ▶ Sécuriser toutes les entrées
- ▶ Entraînement / Formation
 - ▶ Tout le monde peut-être une cible
 - ▶ Minimiser les chances de succès en incluant ceci dans l'entraînement du personnel
 - ▶ Jeux de rôles internes

35

Qui connaît l'autre et se connaît lui-même, peut livrer cent batailles sans jamais être en péril.

L'art de la Guerre, (-400), Sun-Tzu

36

Quelles contremesures

- ▶ Tester régulièrement sa résistance au SE
- ▶ Inclure du SE dans les audits de sécurité
- ▶ Les résultats doivent être tenus confidentiels

37



**"I know a lot of highly-confidential company secrets,
so my boss made me get a firewall installed."**

38